

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

TSEC-FREE-002

Vendor Risk Questionnaire (Lite)

Third-Party Security Due Diligence — Abbreviated Assessment

NIST SP 800-161 | ISO 27001 Annex A.15

Document ID:	TSEC-FREE-002
Version:	1.0
Date:	June 2026
Classification:	CONFIDENTIAL
Prepared by:	TSEC Risk & Cyber Advisory LLC

www.tsecgrc.com | info@tsecgrc.com

1. Purpose

This abbreviated questionnaire is designed to collect key security information from third-party vendors. Complete all sections and return to the requesting organization within 10 business days. Responses will be used to determine vendor risk tier and applicable due diligence requirements.

2. Vendor Information

Field	Response
Company Legal Name	
Primary Contact & Title	
Contact Email / Phone	

Website	
Primary Service / Product Provided	
Data Types Processed (if any)	
Subprocessors / Fourth Parties (list)	

3. Information Security

Security Program		
#	Control / Requirement	Status (✓/X/NA)
1	Does your organization maintain a formal Information Security Policy?	
2	Is a CISO or equivalent security officer designated?	
3	Do you conduct annual security risk assessments?	
4	Do you have a SOC 2 Type II, ISO 27001, or equivalent certification? (Attach if yes)	
5	Is security awareness training provided to all staff annually?	
6	Do you perform background checks on employees with access to customer data?	

Access & Data Protection		
#	Control / Requirement	Status (✓/X/NA)
1	Is multi-factor authentication (MFA) enforced for systems processing customer data?	
2	Is customer data encrypted at rest (AES-256 or equivalent)?	
3	Is customer data encrypted in transit (TLS 1.2+ or equivalent)?	
4	Are access rights reviewed at least annually and upon role changes?	
5	Is a data retention and disposal policy in place?	
6	Do you maintain a data inventory identifying where customer data is stored?	

Incident Response & Business Continuity		
#	Control / Requirement	Status (✓/X/NA)
1	Do you have a documented Incident Response Plan (IRP)?	
2	Will you notify customers of a data breach within 72 hours of discovery?	

3	Have you experienced a security incident in the past 24 months? (If yes, describe)	
4	Do you have a Business Continuity / Disaster Recovery plan?	
5	Are BCP/DR plans tested at least annually?	

4. Certification & Sign-off

I certify that the information provided above is accurate and complete to the best of my knowledge.

Authorized Signatory Name	
Title	
Date	
Signature	